

VIATRIS INC. THREAT MODELING



Viatis Inc.

Robert J. Coury Global Center, 1000 Mylan Blvd, Canonsburg, PA 15317

<https://www.viatis.com/>

\$VTRS

Index

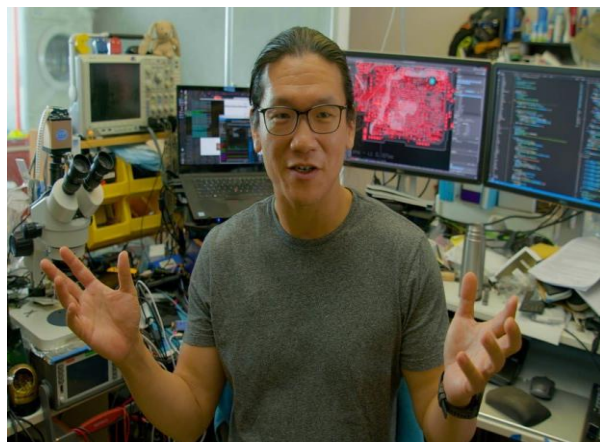
Index	2
Assets	3
Threat Actor 1: Lee Wuyin “Gr33nGu4rdian”	4
Threat Actor 2: Jimmy Johns Volante	6
Threat Actor 3: Walentino White	8
Threat Actor 4: Big Hoss	10
Threat Actor 5: Milton Smaddaw	12
Attack Tree 1: [Redacted]	0
Attack Tree 2: Insider Threat	2
Letter 1: [Redacted]	5
Letter 2: [Redacted]	6

Assets

1. Pharmaceutical manufacturing processes
2. Pharmaceutical R&D data
3. Accounting Data
4. Industrial Machinery
5. Patents
6. Customer & Employee PII
7. Internal / External Data Centers & Servers
8. Agreements
9. Land and buildings
10. Supply chain logistical information

Threat Actor 1: Lee Wuyin “Gr33nGu4rdian”

CyberHacktivist



Age: 35

Sex: Male

Education: Bachelor in Computer Science and Finance

Motives: Social Activism

Skills:

- Well versed with computer infrastructures and networks
- Experienced in exposing sensitive documents from organizations
- Ability to gather media & legal attention

Background

Wuyin, AKA “Gr33nGu4rdian”, is a serial hacktivist who pursues organizations and individuals who have avoided facing the consequences of their actions from a legal sense.

Misuse Cases

Wuyin is experienced in infiltration and reconnaissance to find sensitive documents. He can use media attention to cause reputation loss, and mistrust from Viatrix’ suppliers/clientele. His network of other “hacktivists” can circulate and replicate the sensitive data until his demands are met.

Goals and Motives

He is motivated to bring the current Viatrix CIO to justice, who was caught [conspiring](#) with the Chief of IT from predecessor company Mylan for insider trading. Surprisingly, the DOJ dropped all charges on the CIO. He wants to find out why.

Attack Scenario

Wuyin could infiltrate the Viatrix network by exploiting their unpatched quality management system. He would then gather information about unethical experimentation and production results from their R&D labs in China, India, ending with a DDoS attack to start the panic amongst the C-suite.

Once he is equipped with the information, he would start exploiting Wordpress plugin CVEs and executing CSS attacks to infiltrate the public website and begin defacing efforts, directing attention from social media with bot account posts. For the public, he would geobomb all of Viatrix HQs, production and distribution labs, and clients who retail their pharmaceuticals.

Supported by his Hacktivist group, he would create copies of the sensitive data and incrementally release them on blogs until his demands for justice are met by the DOJ, Viatrix Leadership or by the public. He would threaten the Senior leadership with further disclosures of their unethical practices, unsustainable production means, citing stock price fallacies until they force the CIO to resign.

Actor: Cyber Hacktivist

Threat Type: Targeted

Access Type: Software System

Access Point: Quality Management System

Attack Pattern:

- Infiltrate and disable Quality Management System
- Deface public website
- Copy and leak data

Direct Consequences

- QMS disabled (Availability)
- Sensitive data copied and leaked (Confidentiality)
- Website components changed and defaced (Integrity)

Human Impact	Adversary Motivations	Adversary Resources	Adversary Methods
Financial Wellbeing	Social Justice	Hacktivist Group Resources	Technology Attack
Reputation Damage	Retribution	Expertise	Multi-Channel Attack
Client Impact	Public Wellbeing	Time	Stalking
	Public Shaming and/or Whistleblowing	Community Support Online	

Threat Actor 2: Jimmy Johns Volante

Hacker Group Member



Age: 29

Sex: M

Education: High school graduate, some community college

Motives: Reputation in cohort, mayhem

Skills:

- Highly skilled web developer
- Favors in working with JavaScript and backend functionality of websites
- Extensive knowledge of 3rd and 4th party website infrastructure components and code
- Dogged determination for achieving thrills
- Patience for obtaining desired results (i.e., fine with the long con)

Background

Jimmy Volante is a younger member of the hacker group called Ketchup Nation. He currently works at a small local company in Poland as a web developer, but enjoys defacing websites in his off time. He is looking for targets that may pose difficult to harm. He is looking for big hits to score reputation among his KN cohort.

Misuse Cases

Jimmy will likely attempt to exploit a vulnerability in the company's web infrastructure to deface the website and harm the company's reputation.

Goals and Motives

Jimmy is motivated by challenge and enjoys causing others distress for fun. His goal in life is to have the most fun possible at the expense of moderately distressing other people. In short, he is a troll.

Attack Scenario

He could search for third- or fourth-party exploits in the company's website to deface the site to promote the group's notoriety or to harm Viatrix as a brand and discourage its investors. Though he is not specifically targeting Viatrix and is more interested in causing the most amount of defacement possible, websites are often reliant on 3rd and 4th party code and infrastructure, which is what he specializes in exploiting. The company could be harmed in the process of these exploits.

Actor: Hacker Group Member

Threat Type: Untargeted

Access Type: Website access

Access Point: Website 3rd party infrastructure

Attack Pattern:

- Remote web server access
- Web infrastructure exploit (3rd or 4th party)
- Website defacement

Direct Consequences

- Destruction of website (Availability)
- Interruption of website access (Availability)
- Alteration of website components (Integrity)

Human Impact	Adversary Motivations	Adversary Resources	Adversary Methods
Financial wellbeing (investor deterrent)	Desire	Shared knowledge	Technological attack
Usual wellbeing	Malice	Time	Multi-phase attack
Time to recover	Inconvenience	Web development knowledge	
Brand reputation	Disruption of operations		

Threat Actor 3: Walentino White

Crime Syndicate Leading Member



Age: 46

Sex: M

Education: PhD in Computer Science

Motives: Financial gain, industry mayhem

Skills:

- Highly proficient at writing scripts and programs, most skilled in C++, PHP, Python, R, Ruby, and some assembly code
- Extensive understanding of secure programming principles
- Has a vested interest in abandonware and old, unpatched software versions found in many industrial and manufacturing facilities
- Researching skills from graduate school
- Adept teacher, can disseminate his techniques and ideas to syndicate members

Background

Walentino White is a former computer science professor and researcher. After achieving tenure, he formally joined GGGvrlBoss, a crime syndicate located in Russia. This syndicate offered greater financial compensation and an opportunity to flex his research and technical prowess.

Misuse Cases

His expertise in computer science lies in software security. His research skills and tenacity lends him extensive knowledge to leverage against legacy software that pharmaceutical machinery typically operates on.

Goals and Motives

He was never interested in research for the sake of the common good: He simply wanted to hone his skills to make the most money possible and defecting to Russia was his answer. His goal is to extract R&D intel to improve Russia's stake in the pharmaceutical business because it would pay him well.

Attack Scenario

He could use a phishing email to pose as a Facebook safety and legal officer requiring an employee that has access to the payment systems to click on a link about their child being a victim to AI CP. After getting credentials and infecting the systems, he could move laterally through the network to gain access to R&D intel and client payment information to sell to competitors and potentially create a backdoor to return.

Actor: Crime Syndicate Member

Threat Type: Targeted

Access Type: Credential access

Access Point: email

Attack Pattern:

- Social engineering attack
- Exploitation of legacy software
- Lateral movement in network
- Exfiltration of data

Direct Consequences:

- Leaking data (Confidentiality)
- IAM compromise (Confidentiality, Integrity)
- Internal network compromise (Confidentiality)

Human Impact	Adversary Motivations	Adversary Resources	Adversary Methods
Financial Wellbeing	Money	Expertise	Multi-phase attack
Proprietary data	Malice	Time	Technological attack
Economic wellbeing of the industry	Recognition	Financial sponsorship	Social engineering
	Personal fulfillment	Shared knowledge	

Threat Actor 4: Big Hoss

Cartel Leader



Age: 55

Sex: Male

Education: High School

Motives: Purely Financial Gain

Skills:

- Network of cyber and regular criminals, available on demand
- Skilled in extortion, kidnapping, weaponry, and smuggling
- Has a network of favors among law enforcement, legal, business, and Organized Crime leaders.

Background

Big Hoss is a cartel kingpin, with an eye for moving anything that can cut him a profit. He has been in the drug supply game for 40 years, growing from a delivery boy to the leader he currently is. Currently, he is looking to expand his supply with mass production machinery to meet greater demands.

Misuse Cases

He knows how to assemble a team for a specific purpose, share only required knowledge and get the job done under the target time. He has his influence among computer science undergrads from UPitt and will leverage their expertise for his latest idea. He also has criminals on demand, ready to throw away their lives for a chance at Cartel promotion glory.

Goals and Motives

Hoss's motives are purely financial. He will look for an ROI on every expense made, and wants to get into producing and supplying Opiates, Xanax, Fentanyl, Oxycodin, and Adderall. His goals are to discover the proprietary recipes, and machinery sources for producing these drugs - which are the best-selling products of Viatrix. He discovered the convenience and profit margin of cybercrime and has been addicted ever since.

Attack Scenario

Big Hoss has assembled a team of young Compsci undergraduates along with experienced, hardened professionals to scope out Viatrix. The team starts with kidnapping an IT Admin walking his dog, and getting his location locked secure two factor credentials. They hold the dog hostage for further extortion.

They demand the IT Admin to plug in a USB that allows remote execution, and gain access to the system; Once they have the two factor credentials, the hackers move laterally into the network, finding supply chain logistics and machine maintenance logs. They now have the required components, yet are missing the recipes.

They stealthily deploy a TCP and HTTP monitoring C2 phase using Netcat and observe communications for gaining access to research data. The hackers replicate and fingerprint the valuable directories, securing the recipes; Then move to insert a spyware program with an untraceable signature within audit files.

The program replicates every new row of data of customer and employee's financial information. To avoid suspicion, the hackers edit access logs to remove all records of entry and editing except one, the IT Administrators.

Big Hoss returns the dog to the admin, along with \$500,000, and a portfolio document of every family member he has, and their PII. The IT Admin is told to leave his job after 3 months, and shift to Brazil and start a new life, to which he agrees.

Actor: Cartel Kingpin

Threat Type: Targeted

Access Type: Secure website

Access Point: Physical, Network Access

Attack Pattern:

- On-site port exploit
- Two-factor authentication bypass
- Replicate Recipes & Machinery Lists
- Discreetly leave malware for future data gathering
- Frame IT Admin if discovered

Direct Consequences

- Sensitive Data Replicated (Confidentiality)
- IAM Compromise (Integrity & Confidentiality)

Human Impact	Adversary Motivations	Adversary Resources	Adversary Methods
Financial Wellbeing	Proprietary Information	Hackers and Criminal groups	Kidnapping and Extortion
Physical Wellbeing	Money	Capital	Technology Attack
Time To Detect	Financial Records	Impunity	Multi-Phase Attack
	Influence	Time	

Threat Actor 5: Milton Smaddaw

Disgruntled Laboratory Worker



Age: 56

Sex: Male

Education: Associate's Degree in Laboratory Technology

Motives: Revenge

Skills:

- Extensive knowledge of the deprecated Operating Systems and Industrial Control Systems of the manufacturing and laboratory equipment
- 35+ years of experience in pharmaceutical manufacturing with Viatris

Background

Milton worked in the Viatris warehouse and attended school part-time to earn his Associate's Degree. After being promoted into the lab, Milton worked hard to become a Subject Matter Expert in as many areas as he could. However, Milton's abrasive nature and resistance to change has caused him to be passed over for promotions and he has become resentful of management.

Misuse Cases

Milton is the only employee with a deep understanding of many of the facility machines and their associated systems. From a business perspective, he is a single point of failure until newer workers can be brought up to speed. Even then, much of the equipment is out of support and if unable to be repaired would require complete replacement with a new system.

Goals and Motives

Milton, having skills that while not in high demand are rare and well paid, has been interviewing competing pharmaceutical companies for higher titled positions. When he leaves, he wants to be sure that the company regrets not appreciating his skills and contributions.

Attack Scenario

Using his extensive knowledge of the Industrial Control Systems, he plans to implement misconfigurations on several systems in his last week of work in such a way that a small drift in performance will slowly worsen over time, eventually creating batches of medicines that are out of tolerance but difficult to resolve. Using his scripting abilities on the older software platforms, he also plans to plant several time-bombs to activate periodically through the year. These will cause more immediate and dramatic impacts to the equipment, and continually increase the active issues within the department.

Actor: Insider Threat

Threat Type: Targeted

Access Type: Credentialed / Privileged / Physical Access

Access Point: Physical

Attack Pattern:

- Malicious Misconfigurations
- Time-Bombs

Direct Consequences

- Batches of medicines out of tolerance (Integrity)
- Destruction of legacy equipment (Availability)
- Manufacturing and/or Lab downtime (Availability)

Human Impact	Adversary Motivations	Adversary Resources	Adversary Methods
Financial	Malice	Expertise	Technological Attack
Safety	Revenge	Time	Multi-phase Attack
Operational	Recognition	Trust from Peers	

Attack Tree 1: [Redacted]

Goal: Take over the account of [Redacted] for account access to payments and obtain sensitive information about the company through a spear phishing attack.

Gather reconnaissance: (See part 1)

- Social media is public (Facebook and Tiktok)
- Company's Business Admin Executive - Viatris
 - Acting as the first point of contact / the crossover for 3 departments
 - Pharmacy Sales
 - Commercial Support: NPIs payments/credits
 - Marketing

Craft phishing message to personal email from a fake domain for Meta support page

"Dear [Redacted],

It has come to our attention that your [Redacted] has been the victim of [Redacted]. It has been traced to photos containing images from your Facebook account. It has since been taken down from our site. For Meta's Trust and Safety team to proceed further, please contact Meta's consumer safety helpline (412-839-2909) or follow the link below to submit a case for Facebook to take action. We appreciate your urgency in this matter.

As a long-time Facebook user since 2010, we apologize for the circumstances and will make sure to protect our users such as you [Redacted].

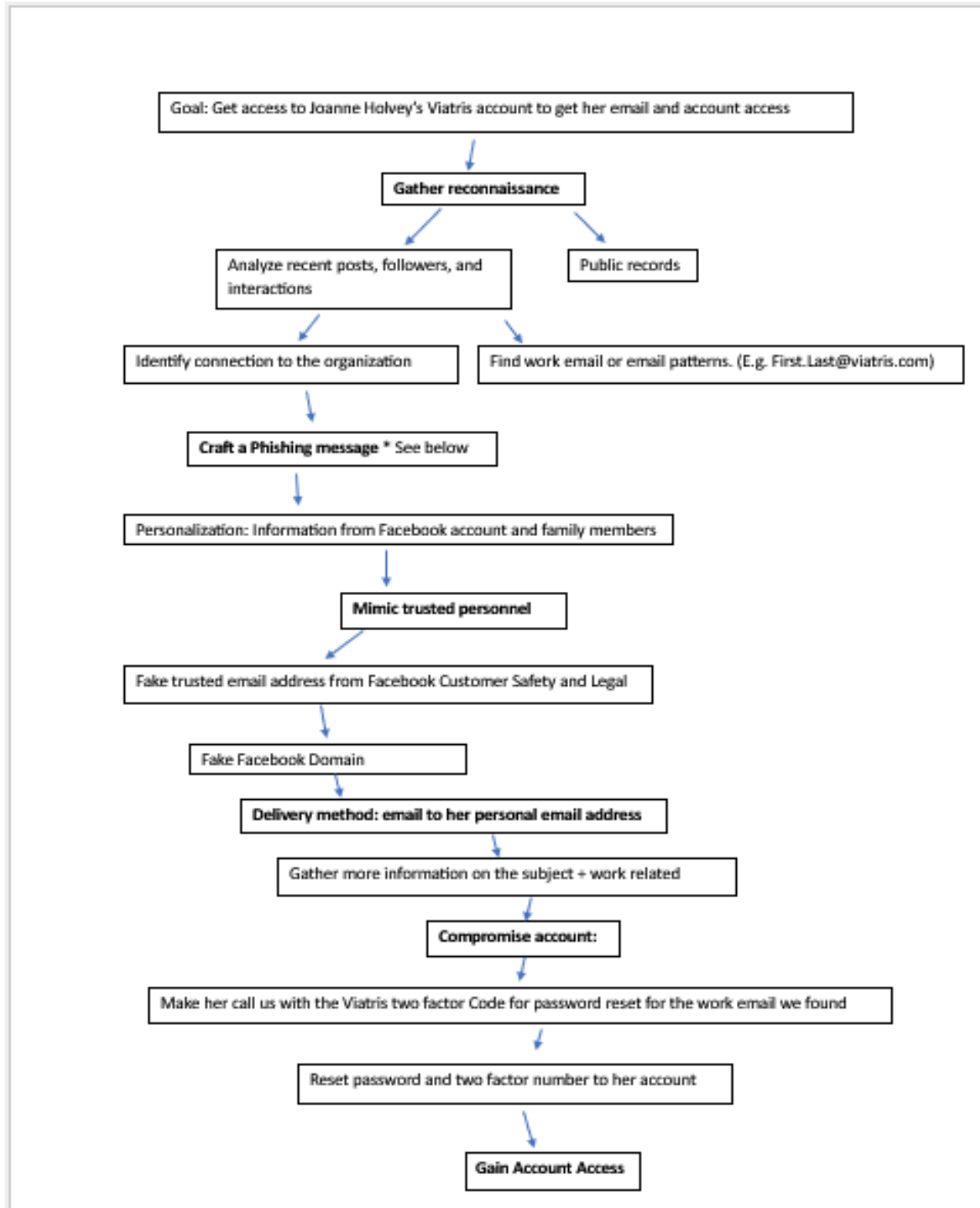
Sincerely,

Amaia Moore

Amaia Moore

Legal Counsel, EMEA Content, Safety & Integrity Legal at Meta "

The link redirects to a fake FB site to input account information and still tells her to call us afterwards to reset work account information ([Redacted]) off the two factor authentication.

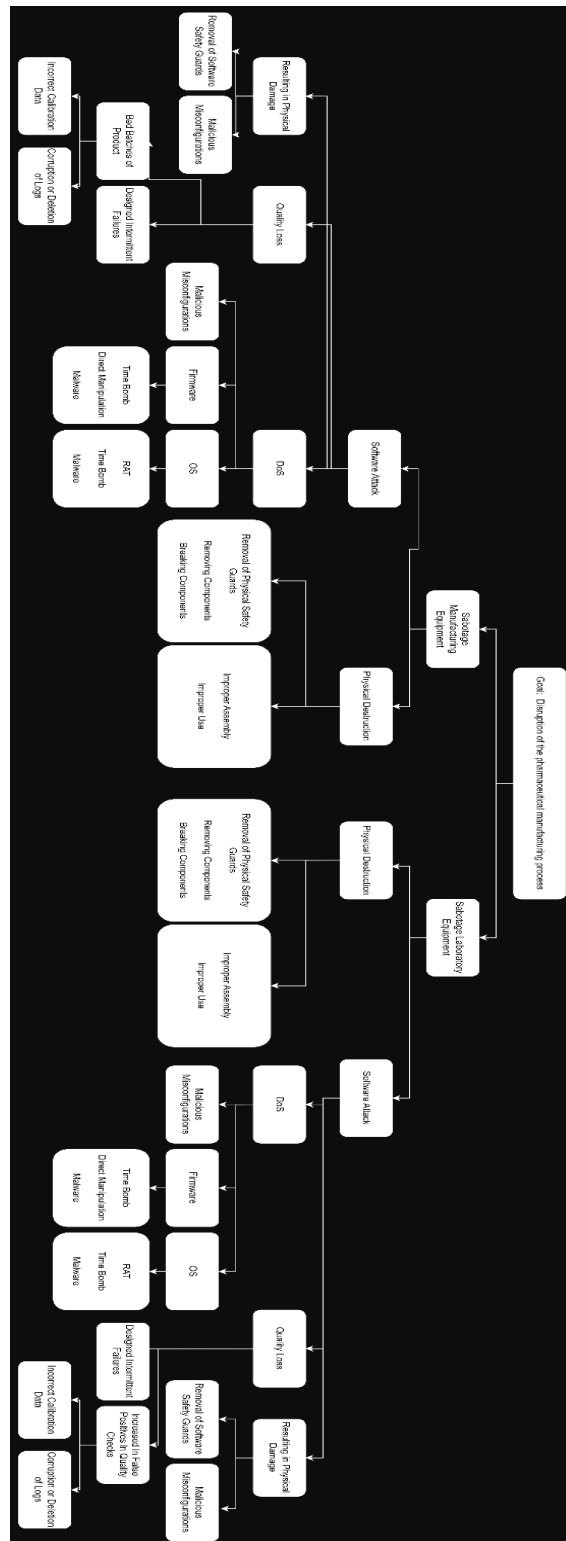


Attack Tree 2: Insider Threat

Graphical Representation provided below

- Goal: Disruption of the pharmaceutical manufacturing process
 - Sabotage Manufacturing Equipment
 - Physical Destruction
 - Breaking components
 - Removing components
 - Improper use
 - Improper assembly
 - Removal of physical safety guards
 - Software Attack
 - Resulting in software related DoS
 - Corruption of high-level OS
 - RAT
 - Continuous reinfection
 - Time-Bomb
 - Direct manipulation
 - Malware
 - Corruption of equipment firmware
 - Time-Bomb
 - Direct manipulation
 - Malware
 - Malicious communication misconfigurations
 - Resulting in physical damage to machine
 - Malicious misconfigurations
 - Removal of software safety guards
 - Resulting in loss of quality
 - Producing bad batches of product
 - Entering incorrect calibration data
 - Corruption or deletion of logs
 - Designed intermittent failures
 - Sabotage Laboratory Equipment
 - Physical Destruction
 - Breaking components
 - Removing components
 - Improper use
 - Improper assembly
 - Removal of physical safety guards
 - Software Attack
 - Resulting in software related DoS
 - Corruption of high-level OS
 - RAT

- Continuous reinfection
 - Time-Bomb
 - Direct manipulation
 - Malware
 - Corruption of equipment firmware
 - Time-Bomb
 - Direct manipulation
 - Malware
 - Malicious communication misconfigurations
- Resulting in physical damage to machine
 - Malicious misconfigurations
 - Removal of software safety guards
- Resulting in loss of quality
 - Increase false positives in quality checks
 - Entering incorrect calibration data
 - Corruption or deletion of logs
 - Designed intermittent failures



Letter 1: [Redacted]

Dear [Redacted],

We are a Cyber Intelligence team at [Redacted] that was hired by Viatris to help you improve your online security posture. A recent attack plan was found online for Viatris Inc. with you as one of their prime targets.

The attackers were able to find where you, your [Redacted] live, phone numbers, email addresses, and one of our team members recently sent you a request to follow on your private Instagram account to test your personal security posture, and you accepted their request. Many of the religious and business expos you and your [Redacted] have attended have also been posted online.

While most of your online presence maintains the safety of your personal information, some of it does not, likely due to data brokering or your own personal decisions with your personal Instagram. Most importantly, you should seek to aid your parents in removing their online presences as their information was the easiest to recover.

Moving forward, we have some recommendations for you:

- Be vigilant about what information is readily available online. You should consider investing in digital safety products that work with data brokers to remove personal data. Personal privacy advances have been made since the EU enrolled GDPR, which the United States is subject to for businesses that have operations within the EU. Some real estate websites that hold your family's personal information may be where you start first.
- You should not accept requests for connection on social media from individuals you do not know. Information, including your traveling habits, conferences you attend, and personal interests may all be used against you in a spear phishing campaign to harm you and/or Viatris Inc.
- Opt to be an anonymous donor to organizations that you support. Keeping your names private may protect you in the future from specialized social engineering tactics. This suggestion should also be shared with your family members that actively participate in the [Redacted] business organizations.

Please be more vigilant about who you allow into your personal circles, both online and offline and take an active role in your parents' organizational presence to help protect them and by relation, our organization. You are a high value target for cyber criminals because of your important role at Viatris Inc. Please reach out if you have any concerns or wish to learn more about protecting your personal information. We will be glad to assist you.

Sincerely,
Cyber Intelligence Team

Letter 2: [Redacted]

Dear [Redacted],

We are a Cyber Intelligence team at [Redacted] and were hired by Viatris to construct our report to identify vulnerabilities in the company. Unfortunately, we chose you to initiate the attack. Your profile piqued our interest because of how much information we could get from you just by simply searching by Viatris. Your LinkedIn was especially scrutinized as we found your professional projects and teams at Viatris. We were able to see your email, phone number, addresses, and 4 pages of work history spanning back from when you graduated high school. We understand that this might be invasive, but we've only used the information we found online that you have put up. It is important to understand your digital footprint as you can see during our attack, we were able to get you to click on a phishing email from Facebook trust and safety to compromise both your personal and your work email. You and your [Redacted] are in no danger, and you have job security as this was a phishing test and not an actual incident.

Here are some steps to make sure your digital footprint does not become weaponized:

Clean up your social media

- Delete old photos off your social media especially since we were able to get information that you [Redacted] offered your [Redacted].
- Clean up any information that you have on your LinkedIn that is not relevant and do not put your resume as public with sensitive information like your phone number or your email. LinkedIn allows you to post your work history. It is not necessary for you to upload your resume. Only job applications and known authorized individuals should receive your resume.
- Verify emails that are asking you for immediate action by contacting the source directly instead of through email. Putting a ticket in with Facebook's trust and safety to double-check if this is real would have helped you mitigate this risk. I understand that such an extreme measure was taken by claiming that your [Redacted] was the victim of [Redacted] but the point of fishing is to make sure that you are in a panic and click on the link without a second thought.

We understand personal life and work life are two separate things but when you start putting information out there that relates to your work you become a victim to potentially heinous acts like this.

Protect yourself, your family, and your workplace by second-guessing what you make public.

Sincerely,
Cyber Intelligence Team